

Phase 3: Defensive Strategy Proposal

Defense Mechanism 1: Fail2Ban

We used Fail2Ban as a defensive strategy. It watches login attempts on the server and blocks any IP that fails to log in too many times. This helps stop brute-force attacks like the one done by Hydra.

1. First Install Fail2Ban:

```
vagrant@metasploitable3-ub1404:~$ sudo apt install fail2ban -y
Reading package lists... Done
Building dependency tree
Reading state information... Done
The following packages were automatically installed and are no longer required:
  amd64-microcode linux-modules-extra-3.13.0-170-generic
Use 'apt-get autoremove' to remove them.
The following extra packages will be installed:
  python-pyinotify whois
Suggested packages:
  python-gamin mailx python-pyinotify-doc
The following NEW packages will be installed:
  fail2ban python-pyinotify whois
0 upgraded, 3 newly installed, 0 to remove and 5 not upgraded.
Need to get 184 kB of archives.
After this operation, 927 kB of additional disk space will be used.
Get:1 http://us.archive.ubuntu.com/ubuntu/ trusty/universe fail2ban all 0.8.11-1 [129 kB]
Get:2 http://us.archive.ubuntu.com/ubuntu/ trusty/main python-pyinotify all 0.9.4-1build1 [24.5 kB]
Get:3 http://us.archive.ubuntu.com/ubuntu/ trusty/main whois amd64 5.1.1 [30.2 kB]
Fetched 184 kB in 2s (81.9 kB/s)
Selecting previously unselected package fail2ban.
(Reading database ... 129348 files and directories currently installed.)
Preparing to unpack .../fail2ban_0.8.11-1_all.deb ...
Unpacking fail2ban (0.8.11-1) ...
Selecting previously unselected package python-pyinotify.
Preparing to unpack .../python-pyinotify_0.9.4-1build1_all.deb ...
Unpacking python-pyinotify (0.9.4-1build1) ...
Selecting previously unselected package whois.
Preparing to unpack .../archives/whois_5.1.1_amd64.deb ...
Unpacking whois (5.1.1) ...
Processing triggers for man-db (2.6.7.1-1ubuntu1) ...
Processing triggers for ureadahead (0.100.0-16) ...
ureadahead will be reprofiled on next reboot
Setting up fail2ban (0.8.11-1) ...
* Starting authentication failure monitor fail2ban
Setting up python-pyinotify (0.9.4-1build1) ...
Setting up whois (5.1.1) ...
Processing triggers for ureadahead (0.100.0-16) ...
vagrant@metasploitable3-ub1404:~$
```

2. Check logs:

```
vagrant@metasploitable3-ub1404:~$ sudo cat /var/log/fail2ban.log
2025-05-02 16:38:01,753 fail2ban.server : INFO Changed logging target to /var/log/fail2ban.log for Fail2ban v0.8.11
2025-05-02 16:38:01,754 fail2ban.jail : INFO Creating new jail 'ssh'
2025-05-02 16:38:01,847 fail2ban.jail : INFO Jail 'ssh' uses pyinotify
2025-05-02 16:38:01,885 fail2ban.jail : INFO Initiated 'pyinotify' backend
2025-05-02 16:38:01,886 fail2ban.filter : INFO Added logfile = /var/log/auth.log
2025-05-02 16:38:01,888 fail2ban.filter : INFO Set maxRetry = 6
2025-05-02 16:38:01,889 fail2ban.filter : INFO Set findtime = 600
2025-05-02 16:38:01,889 fail2ban.actions: INFO Set banTime = 600
2025-05-02 16:38:01,926 fail2ban.jail : INFO Jail 'ssh' started
```

3. Create the jail file using `sudo nano /etc/fail2ban/jail.local` then write this:

```
[sshd]
enabled = true
port = ssh
filter = sshd
logpath = /var/log/auth.log
maxretry = 5
bantime = 600
```

This configuration will ban IPs that fail SSH login 5 times for 10 minutes.

4. Check the status before applying the hydra attack:

```
vagrant@metasploitable3-ub1404:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
├─ filter
│  ├─ File list: /var/log/auth.log
│  ├─ Currently failed: 0
│  └─ Total failed: 0
└─ action
    ├─ Currently banned: 0
    └─ IP list:
        └─ Total banned: 0
```

5. Then try to apply the brute force:

```
(basim@Attacker)-[~/Desktop]
$ hydra -L user.txt -P password.txt ssh://10.0.2.15
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or
anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-05-02 19:47:56
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 154 login tries (l:7/p:22), ~10 tries per task
[DATA] attacking ssh://10.0.2.15:22/
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-05-02 19:48:36
```

This message confirms that the defensive mechanism is working correctly.

6. Now we can check the status:

```
vagrant@metasploitable3-ub1404:~$ sudo fail2ban-client status sshd
Status for the jail: sshd
├─ filter
│  ├─ File list: /var/log/auth.log
│  ├─ Currently failed: 1
│  └─ Total failed: 28
└─ action
    ├─ Currently banned: 1
    └─ IP list:
        └─ Total banned: 1
```

We can see that our attacker IP banned.

Before-and-After comparison summary:

- Before: Hydra was able to try many login attempts without any block.

```
basim@Attacker:~$ hydra -L user.txt -P password.txt ssh://10.0.2.15
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret
service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and et
hics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-05-01 19:27:40
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce
the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 5235 login tries (l:15/p:349), ~328 tries per
task
[DATA] attacking ssh://10.0.2.15:22/
[STATUS] 338.00 tries/min, 338 tries in 00:01h, 4901 to do in 00:15h, 12 active
[STATUS] 323.33 tries/min, 970 tries in 00:03h, 4271 to do in 00:14h, 10 active
[STATUS] 280.57 tries/min, 1964 tries in 00:07h, 3277 to do in 00:12h, 10 active
[STATUS] 273.00 tries/min, 3276 tries in 00:12h, 1965 to do in 00:08h, 10 active
[STATUS] 265.88 tries/min, 4520 tries in 00:17h, 721 to do in 00:03h, 10 active
[22][ssh] host: 10.0.2.15 login: vagrant password: vagrant
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-05-01 19:47:32
```

- After: Fail2Ban blocked the attacker's IP quickly, and Hydra could not continue the attack.

```
basim@Attacker:~$ hydra -L user.txt -P password.txt ssh://10.0.2.15
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret
service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and et
hics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2025-05-02 19:47:56
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce
the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 154 login tries (l:7/p:22), ~10 tries per task
[DATA] attacking ssh://10.0.2.15:22/
[ERROR] all children were disabled due too many connection errors
0 of 1 target completed, 0 valid password found
[INFO] Writing restore file because 2 server scans could not be completed
[ERROR] 1 target was disabled because of too many errors
[ERROR] 1 targets did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-05-02 19:48:36
```

This shows the defense was effective in stopping repeated login attempts.

Conclusion:

Fail2Ban worked well to protect the victim machine from the brute-force attack. After many wrong login tries, it blocked the attacker's IP automatically. When we ran Hydra again, it failed to continue the attack. This shows that Fail2Ban helped stop the attack and made the system safer in an easy way.